INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC102 – INFORMATION SECURITY GOVERNANCE

Practical Lab 5: Monitoring Auditing Controls and Executive Reporting

Role:Security Governance Analyst

Student Name	Olubunmi Adesanmi
Registration Number	C11/26/CGRCE/17550
Course	GRC102 – Information Security Governance
Role	Security Governance Analyst
Submission Date	11 October 2026

Table of Contents

Executive Summary

1. Introduction

2. Objectives, Scope and Limitations

3. Lab Environment and Components

4. Methodology and Evidence Approach

5. Vulnerability Assessment Results

6. Governance Failure Analysis

7. Governance Registers and Risk Status

8. Security Metrics and Dashboard

9. Corrective Action Plan

10. Control Retesting and Residual Risk

11. Audit and Incident Records

12. Recommendations

13. AI Usage Declaration

14. Conclusion

References

Executive Summary

This report documents the practical implementation and governance analysis activities undertaken for the GRC102 Week 5 Linux lab. The work involved preparing a container-based lab configuration, executing Python scripts, generating vulnerability assessment results, analysing governance failures, maintaining governance data, and producing a security governance dashboard.

The vulnerability assessment report recorded three checks. The scanner reported insufficient network segmentation as a medium-severity finding, did not detect access using default MySQL credentials, and could not determine whether the Struts2 vulnerability was present because the web application hostname could not be resolved.

The governance failure analysis identified three issues: ineffective patch management policy implementation, security metrics that were not driving effective remediation, and insufficient network segmentation. The governance dataset also contained eight controls recorded as implemented and three open risks rated Critical, High, and Medium.

The governance dashboard summarised policies, controls, risks, incidents, metrics, and audit records. Its output revealed that the vulnerability-remediation-time and security-incident metrics were marked Green even though their recorded values missed their targets. This indicates a need to review metric threshold logic and validate dashboard classifications.

The lab experienced technical limitations, including a missing Struts2 image tag, hostname resolution failure, and a container-service connection problem. The attack simulation did not complete successfully, and the governance analysis reported that no attack log was found.

Accordingly, this report distinguishes implemented project artefacts from verified security outcomes. The available evidence demonstrates practical development and governance analysis, but successful remediation and post-remediation control effectiveness have not been established.

1. Introduction

Information security governance ensures that an organisation's information security activities support its objectives and that security risks are managed through appropriate policies, responsibilities, controls, and oversight.

Technical tools can identify weaknesses, but the results must be interpreted in a governance context. For example, an unpatched vulnerability may indicate a technical problem, but it may also reveal failures in patch-management procedures, risk ownership, escalation, or management oversight.

The National Institute of Standards and Technology Cybersecurity Framework 2.0 includes the Govern function to emphasise the importance of cybersecurity strategy, organisational responsibilities, policies, and oversight (National Institute of Standards and Technology [NIST], 2024).

This lab applied similar principles in a simulated environment. The work involved reviewing vulnerability results, analysing security governance failures, examining reported control implementations, and identifying how metrics and executive dashboards can support decisions.

2. Objectives, Scope and Limitations

2.1 Objectives

The objectives of the lab were to:

1. Simulate security governance scenarios in a controlled Linux environment
2. Analyze security logs and events to identify governance failures
3. Implement security governance controls based on case study lessons
4. Develop security metrics and reporting mechanisms
5. Create a security governance dashboard for executive reporting

6.Apply lessons from case studies to practical security governance implementation

2.2 Scope

The report covers the container-based lab configuration; the project scripts and governance data; the vulnerability assessment report; governance failure analysis; risk, policy, control, incident, audit and metric records; dashboard classifications; and the identified supporting visualisation files

2.3 Limitations

1. The Struts2 check was inconclusive because the application hostname could not be resolved.

2.The simulated attack did not complete successfully, and no attack log was found by the governance analysis.

3. No post-remediation scan or verified retest results were included in the supplied evidence.

4. The underlying plotted values in the PNG visualisations were not independently inspected for this report.

5. Some policies have recorded review dates in 2024; the supplied dataset does not establish whether later reviews took place.

6.The report treats values in the governance dataset as recorded data, not as independently verified operational measurements.

3. Lab Environment and Implementation

3.1 Environment configuration

This practical laboratory was conducted in a Kali Linux environment using a container-based configuration. The lab environment comprised a Docker Compose configuration, database initialization files, monitoring-related resources, Python scripts for security testing and governance analysis, governance data files, and generated reports and visualisations.

3.2 Implemented project components

The project included the following artefacts:

Component	Purpose
Compose configuration	Defines the intended container services

database_init/	Contains database initialization files
monitoring/	Contains monitoring-related files
vulnerability_scanner.py	Performs the lab's configured vulnerability checks
simulate_attack.py	Attempts the configured Struts2 attack simulation
patch_management.py	Supports patch-management activities
initialize_governance.py	Supports governance data initialization
governance_tracker.py	Lists and tracks governance records and generates a dashboard
analyze_governance_failures.py	Analyses governance failure scenarios
governance_data.json	Stores governance records
metrics_visualizations	Contains PNG visualizations for selected security metric

4. Methodology

The assessment followed a structured process.

4.1 Evidence collection

The lab directory was reviewed to identify generated scripts, reports, JSON files, dashboards, and visualisations. The vulnerability scan and governance failure analysis outputs were then examined.

4.2 Vulnerability assessment

The vulnerability scan results were reviewed to identify reported findings, severity, test errors, and recommended remediation. Inconclusive checks were treated as requiring further investigation rather than as confirmed vulnerabilities or confirmed remediation.

4.3 Governance failure analysis

The governance failure report was examined to identify weaknesses in policy implementation, measurement, technical architecture, and authentication and access control.

4.4 Control review

The security governance controls implementation report was reviewed to determine which controls were reported as implemented and what evidence would be needed to verify their effectiveness.

4.5 Metrics and executive reporting

The file inventory was reviewed to identify the available dashboard, reporting, and visualisation artefacts. Since the actual numerical dashboard outputs and the contents of every reporting file were not examined, no unverified metric values have been treated as confirmed results.

4.6 Evidence limitations

The report distinguishes three types of evidence:

- **Observed result:** Information directly visible in the supplied command output or report.
- **Reported implementation:** A control described as implemented in a lab report.
- **Verification required:** A control whose successful operation has not been independently demonstrated by the available evidence.

This distinction supports accurate governance reporting and prevents implementation claims from being mistaken for verified security outcomes.

5. Vulnerability Assessment Results

The vulnerability scanner generated the report file vulnerability_report_20261010_202924.json. The supplied report contained three checks. Results are summarised below.

ID	Check / finding	Result	Severity	Recommended follow-up
V-01	Apache Struts2 S2-045 (CVE-2017-5638)	Inconclusive; hostname resolution failed.	Unknown	Restore authorised lab application connectivity, verify the affected version and configuration, and repeat the check.

V-02	MySQL using default credentials	Default-credential access was not detected in the performed check.	N/A	Retain the result and separately review database accounts, authentication settings, and permissions.
V-03	Insufficient network segmentation	It is a vulnerability; web servers could directly access database servers.	Medium	Restrict inter-service connectivity to approved requirements and repeat authorised connectivity tests.

5.1 Interpretation

Struts2: The scanner could not establish whether CVE-2017-5638 was present because the application hostname could not be resolved. An inconclusive result is neither a confirmed vulnerability nor evidence that the application is secure. The vulnerability reference is documented in the National Vulnerability Database (National Institute of Standards and Technology, n.d.). The application image reference and service connectivity need to be checked before the test can produce a meaningful result.

Database credentials: The result indicates that the particular default-credential check did not detect access. It does not demonstrate that all database authentication, authorisation, or configuration controls are effective. Oracle's MySQL security guidance provides relevant background for reviewing database security settings (Oracle, n.d.). A broader authorised review is still required.

Network segmentation: The reported direct connectivity from web server to database server indicates that the permitted communication boundary may be wider than necessary. Unnecessary paths can increase the potential for lateral movement if an exposed component is compromised. Network segmentation is also addressed in the Center for Internet Security's safeguards (Center for Internet Security, n.d.). Any changes should be followed by connectivity tests that demonstrate only approved paths are available.

5.2 Assessment summary

The scanner report recorded three checks, with one medium-severity finding and one unknown result. No high or critical findings were reported by these checks. This summary

applies only to the checks represented in the report and should not be interpreted as evidence that the entire environment is free of other vulnerabilities.

6. Governance Failure Analysis

The script analyze_governance_failures.py completed and generated governance_failure_report_20261011_002329.json. The report identified three governance failures.

ID	Category	Identified failure	Governance implication and response
GF-01	Policy implementation	Patch Management Policy not effectively implemented.	Critical vulnerabilities may remain unpatched despite a policy. Define owners, deadlines, escalation, exceptions, and closure evidence.
GF-02	Metrics and measurement	Security metrics not driving effective remediation.	Metrics must trigger owned corrective actions when targets are missed; otherwise they provide limited assurance.
GF-03	Security architecture	Insufficient network segmentation.	Limit application-to-database paths according to least privilege and verify the resulting network boundaries.

6.1 Policy implementation

The findings indicate a gap between having a patch-management policy and ensuring that identified vulnerabilities are addressed. A policy should be supported by defined remediation

responsibilities, deadlines, escalation procedures, exception management, and evidence of completed fixes.

The patch-management script was included in the project, but the available information does not establish that all necessary patches were applied successfully.

6.2 Metrics and measurement

Security metrics should support decision-making and trigger corrective actions when performance falls outside acceptable limits. The analysis identified a weakness in the connection between metrics and remediation.

Each metric should have a defined calculation method, target, responsible owner, reporting frequency, escalation threshold, and link to a corrective-action process.

6.3 Security architecture

The reported network-segmentation issue could permit unnecessary access between application and database components. Network controls should apply least privilege and allow only communication necessary for approved business and technical functions.

The control was recorded as implemented in the governance dataset, but the scanner still reported a segmentation weakness. This discrepancy requires investigation and retesting.

The analysis output stated that no attack log was found. Consequently, it does not establish that a successful attack occurred or that attack-log evidence was analysed.

7. Governance Register and Control Status

The dataset governance_data.json contained four policies, eight controls, three risks, one incident, five metrics, and one audit record.

The governance_data.json dataset contained four policies, eight controls, three risks, one incident, five metrics, and one audit record.

Record type	Count	Review note
Policies	4	Three policy review dates were recorded in 2024; confirm whether later reviews occurred.
Controls	8	All eight were recorded as implemented; this is not by

		itself evidence of effectiveness.
Risks	3	One Critical, one High, and one Medium risk; all recorded as open.
Incidents	1	One historical High-severity incident was recorded as closed.
Metrics	5	Two Green dashboard classifications conflict with recorded targets and actuals.
Audits	1	One Annual Security Audit was recorded as completed.

7.1 Policy register

Four policies were recorded as active:

- Patch Management Policy
- Vulnerability Management Policy
- Incident Response Policy
- Security Governance Oversight

The Patch Management, Vulnerability Management, and Incident Response policies had review dates in 2024. As of 11 October 2026, these dates had passed. The dataset does not establish whether later reviews took place, so their review status should be confirmed.

Security Governance Oversight was recorded as approved on 10 October 2026, with a review date of 10 October 2027.

7.2 Control register

Eight controls were recorded as implemented, covering patch management, vulnerability scanning, incident response, automated patch management, network segmentation, database security, real-time security monitoring, and executive security oversight.

A recorded implementation status is not sufficient evidence of operating effectiveness. For example, the network-segmentation control was recorded as implemented while the scanner reported insufficient segmentation. Automated patch management was also recorded as implemented while the unpatched-vulnerability risk remained open.

These inconsistencies demonstrate the need to support control status with current evidence, functional testing, and documented retesting results.

7.3 Risk register

Risk ID	Risk description	Likelihood	Impact	Recorded level	Status	Owner
RISK-001	Unpatched vulnerabilities	High	High	Critical	Open	Security Engineer
RISK-002	Insufficient network segmentation	Medium	High	High	Open	Network Engineer
RISK-003	Weak authentication	Medium	Medium	Medium	Open	Identity Manager

RISK-001 requires priority attention because it is rated Critical and remains open. RISK-002 also requires remediation because insufficient segmentation may increase the potential for lateral movement. RISK-003 remains open and requires verification of authentication controls, including multi-factor authentication where appropriate.

The risks should remain open until suitable remediation and verification evidence is recorded.

8. Security Metrics and Governance Dashboard

The governance tracker provided options for listing policies, controls, risks, incidents, metrics, and audits, as well as generating a dashboard.

8.1 Dashboard summary

Governance record	Count
Policies	4
Controls	8
Risks	3
Incidents	1
Metrics	5
Audits	1

The dashboard recorded one Critical risk, one High risk, and one Medium risk. It also recorded one High-severity incident.

8.2 Metric values and status review

Metric	Target	Recorded actual	Dashboard status	Assessment
Patch Compliance — May 2023	95%	85%	Red	Consistent with a 10-percentage-point shortfall.
Vulnerability Remediation Time — May 2023	7 days	12 days	Green	Inconsistent: actual exceeds target by 5 days.

Security Incidents — May 2023	0	1	Green	Inconsistent with a target of zero incidents.
Critical Patch Compliance — October 2026	100%	100%	Green	Meets recorded target; calculation and evidence still require validation.
Security Monitoring Coverage — October 2026	100%	100%	Green	Meets recorded target; calculation and evidence still require validation.

The first three metrics were recorded for May 2023, whereas the last two were recorded for October 2026. The different reporting periods should be considered when interpreting the figures.

The remediation-time and security-incident metrics were incorrectly or inconsistently classified as Green based on the supplied targets and actual values. The dashboard logic should be reviewed so that performance outside an accepted threshold triggers an appropriate warning or escalation.

The October 2026 figures reported 100% critical-patch compliance and 100% monitoring coverage. The available evidence does not establish how these measurements were calculated or independently validated. They also require reconciliation with the open Critical unpatched-vulnerability risk and the need to verify monitoring coverage.

8.3 Visualization evidence

The project contained five PNG files under metrics_visualizations/:

- patch_compliance.png
- vuln_remediation.png
- security_incidents.png
- monitoring_coverage.png
- policy_compliance.png

These files are identified as supporting visualizations. Their underlying plotted values have not been independently inspected as images for this report. The numerical discussion above is based on the supplied governance dataset and dashboard output.

9. Patch Management and Corrective Actions

The project included patch_management.py. The available evidence confirms that the script was created or run, but does not confirm whether it installed patches, completed remediation successfully, or verified the resulting system state.

The following corrective actions are recommended:

Priority / issue	Recommended action	Responsible role in dataset	Evidence required for closure
Critical — unpatched vulnerabilities	Identify affected assets, prioritise and apply approved patches, document exceptions, and rescan.	Security Engineer	Asset and patch status, change record, exception approval if applicable, and repeat scan results.
High — network segmentation	Restrict unnecessary inter-service communication based on approved application requirements.	Network Engineer	Approved network rules and documented connectivity tests showing only permitted paths.
Database authentication	Review database accounts, authentication settings, privileges, and account lifecycle.	Database Administrator	Configuration review and authorised access-test results.
Dashboard metric misclassification	Correct threshold logic and test status calculations against known inputs.	Security Engineer or metrics owner	Test cases, expected/actual status comparison, and corrected dashboard output.

Potentially overdue policy reviews	Confirm current policy versions and complete any outstanding reviews.	Relevant policy owners	Dated review records, approvals, updated versions, and next review dates.
Monitoring assurance	Confirm critical assets produce usable monitoring data and coverage is calculated consistently.	Security Engineer	Asset coverage inventory and evidence of functioning log collection.
Struts2 connectivity	Verify the configured image reference, hostname, and service networking in the authorised lab.	Lab owner / technical owner	Successful service health check and a repeat scanner result with the test conditions recorded.
Audit follow-up	Track audit recommendations through remediation and independent or peer verification.	Designated audit / control owners	Action tracker, closure approvals, and supporting evidence.

These actions are recommendations rather than confirmed completed changes. Their status should be updated when implementation and verification evidence becomes available.

10. Control Retesting and Residual Risk

The available evidence does not confirm successful post-remediation testing. The vulnerability scanner was remembered as having been run to generate the existing report, but no repeat scan or comparison was recalled.

The current assurance position is as follows:

Control area	Evidence available	Current retesting status

Struts2 vulnerability	Scanner could not resolve the application hostname.	Inconclusive; repeat test required after authorised lab connectivity is restored.
Patch management	patch_management.py is included in the project.	Successful patching and post-patch verification are unverified.
Network segmentation	Scanner reported direct access from web server to database server.	Corrective change and successful retest are unverified.
Database security	Default-credential access was not detected in the performed check.	Other authentication and authorisation controls remain unverified.
Dashboard metrics	Two Green classifications conflict with their target and actual values.	Threshold correction and validation are required.
Monitoring coverage	Dashboard recorded 100% coverage for October 2026.	Calculation, asset scope, and collection functionality require evidence.

The Critical and High risks should remain open until the relevant controls have been tested and sufficient evidence demonstrates that the risks have been reduced. The residual risk should be reassessed after corrective actions are implemented and verified.

The Struts2 application should only be tested within the authorised, isolated lab environment. Its image reference and service connectivity need to be resolved before a valid application test can take place.

11. Audit and Incident Records

The governance dataset recorded an Annual Security Audit dated 1 May 2023 as completed. Its findings referred to patch management and network segmentation, and the recommendations included improving patch management and implementing segmentation. The supplied data does not confirm whether every audit recommendation was closed.

The dataset also recorded a historical High-severity web-server compromise dated 15 April 2023, attributed to an unpatched Struts vulnerability, with the incident marked closed. This is a historical record contained in the governance data and is not evidence that the Week 5 lab simulation successfully reproduced the incident.

Audit and incident records should be used to guide corrective actions, track recurring weaknesses, and support lessons learned. Closure should be supported by documented evidence of remediation and any required verification.

12. Recommendations

Based on the lab results, the following governance improvements are recommended:

1. **Strengthen patch-management oversight.** Establish clear remediation priorities, owners, deadlines, exception approvals, and evidence of completed patches.
2. **Validate control implementation.** Do not treat a control marked as implemented as effective until suitable operational evidence supports that status.
3. **Improve network segmentation.** Restrict communication between application and database services according to least privilege, then verify the intended access boundaries.
4. **Correct metric thresholds.** Review dashboard logic so that missed targets and threshold breaches trigger accurate statuses and escalation.
5. **Improve risk tracking.** Maintain the Critical and High risks as open until the corrective actions and required retesting are evidenced.
6. **Review policy currency.** Confirm the latest review dates for policies whose recorded review dates passed in 2024.
7. **Improve test evidence collection.** Record the date, command or test, expected outcome, actual result, and evidence location for each control test.
8. **Resolve the lab deployment issue.** Verify the configured Struts image reference and service networking within the authorised environment before attempting another application test.
9. **Strengthen audit follow-up.** Track audit recommendations to closure and retain evidence supporting each closure decision.

13. Conclusion

The laboratory produced a set of technical and governance artefacts, including a container configuration, Python scripts, vulnerability assessment results, governance failure analysis, a governance dataset, a dashboard output, and metric visualizations.

The results identified three governance weaknesses involving patch-management policy implementation, security metrics, and network segmentation. The vulnerability assessment also reported insufficient network segmentation and an inconclusive Struts2 result because the web application was unavailable to the scanner.

The dashboard highlighted the need to validate metric classifications and reconcile reported performance with open risks. The project also demonstrated why governance records should

be supported by evidence of actual control operation rather than relying only on implementation status.

Although the lab produced useful evidence for governance analysis and reporting, successful remediation and post-remediation control effectiveness remain unverified. The recommended next steps are to resolve the authorised lab deployment issue where required, verify corrective actions, repeat appropriate control tests, correct metric thresholds, and retain the results as assurance evidence.

The overall conclusion is that the lab supports analysis of security governance failures and demonstrates the importance of connecting policies, controls, risks, metrics, and corrective actions. Final assurance should be based on verified test results and evidence that outstanding risks have been appropriately treated.

References

Center for Internet Security. (n.d.). *Implement network segmentation*. https://www.cisecurity.org/controls/implement-network-segmentation

National Institute of Standards and Technology. (n.d.). *CVE-2017-5638 detail*. National Vulnerability Database. https://nvd.nist.gov/vuln/detail/CVE-2017-5638

Oracle. (n.d.). *MySQL 5.7 Reference Manual: Security*. https://dev.mysql.com/doc/refman/5.7/en/security.html

13. AI Usage Declaration

Generative AI(ChatGPT) was used to assist with organising the supplied lab material into a structured report, refining grammar and professional wording, improving table presentation,

AI was not treated as a source of lab evidence. The reported scanner results, governance counts, risk ratings, metric values, dates, and technical limitations were taken from the supplied lab notes and output summaries